

Dan Boneh 密码学第一季：第八课 零碎主题

本课英文标题为 Odds and Ends，包含四个相对独立但彼此关联的主题：密钥派生、确定性加密、可调加密与磁盘加密、保格式加密。

1. 本课的统一主线

本课讨论的不是一种单独的密码原语，而是四类特殊需求：

1. 只有一个源密钥，却需要生成很多用途不同的子密钥；
2. 数据库需要根据密文查找记录，无法每次都使用随机 nonce；
3. 磁盘扇区长度固定，密文不能比明文更长；
4. 信用卡号等数据经过加密后，仍必须符合原有格式。

这些需求都不能简单地套用“随机 nonce + 普通认证加密”。设计者必须改变加密接口或安全目标，并准确理解由此产生的泄露。

学完本课，应当能够回答：

1. KDF 为什么需要上下文 CTX？
2. 为什么非均匀源密钥要先 Extract，再 Expand？
3. HKDF 与口令 KDF 的目的有什么不同？
4. 为什么确定性加密不可能满足普通 CPA 安全？
5. 确定性 CPA 安全为什么要求同一侧的挑战消息互不重复？
6. 固定 IV 的 CBC 和 CTR 为什么都不是安全的确定性加密？
7. SIV 如何从消息自身产生“合成 IV”？
8. DAE 如何同时实现确定性保密与密文完整性？
9. tweak 与 nonce、密钥有什么区别？
10. XTS 为什么适合磁盘，却不提供数据完整性？
11. FPE 如何把一个大域上的 PRP 限制到信用卡号等小域？

2. 密钥派生函数 KDF

2.1 为什么需要派生多个密钥

系统通常先得到一个源密钥 SK，例如来自：

- 硬件随机数生成器；
- 密钥交换协议；
- 主密钥或共享秘密。

但一个安全会话往往需要多个逻辑独立的密钥：

- 客户端到服务器的加密密钥；
- 服务器到客户端的加密密钥；
- 两个方向的认证密钥；
- IV、nonce 或其他协议状态的派生材料；

- 不同算法、应用或会话的子密钥。

目标是通过 KDF 进行：

$$SK \xrightarrow{KDF} k_1, k_2, k_3, \dots$$

不能简单地把同一把密钥用于所有算法，因为不同用途可能产生跨协议攻击，也会扩大单个密钥泄露的影响。

2.2 源密钥均匀时：用 PRF 扩展

设 F 是安全 PRF：

$$F : K \times \{0, 1\}^* \rightarrow \{0, 1\}^n.$$

如果 SK 在 K 中均匀随机，可以定义：

$$\begin{aligned} KDF(SK, CTX, L) = & F(SK, CTX \parallel 0) \\ & \parallel F(SK, CTX \parallel 1) \\ & \parallel \dots \end{aligned}$$

直到产生至少 L 位输出，再按需要截断。

由于 PRF 在均匀密钥下看起来像随机函数，对不同计数器输入的输出可以作为不同的伪随机密钥材料。

2.3 CTX 的作用：域分离

CTX 是唯一标识用途的上下文字符串，例如：

```
protocol = TLS-like-demo
version = 1
direction = client-to-server
purpose = encryption
session-id = ...
```

如果两个应用偶然使用了相同 SK ，但 CTX 不同，则派生输入不同：

$$F(SK, CTX_1 \parallel i) \quad \text{与} \quad F(SK, CTX_2 \parallel i).$$

在 PRF 假设下，它们看起来像独立随机值。

这称为**域分离**。CTX 通常不保密，它的价值是明确说明“这个输出用于什么”。

建议让 CTX 包含无歧义的编码和用途标签，避免直接拼接长度不明确的字段。例如：

```
ab || c 与 a || bc
```

若编码方式不明确，可能得到同一个字节串。

2.4 为什么非均匀 SK 不能直接当 PRF 密钥

PRF 的安全定义通常假设密钥在 K 中均匀随机。如果 SK ：

- 只分布在 K 的一个子集；
- 存在偏置；
- 含有攻击者已知的部分结构；

那么直接计算 $F(SK, x)$ 不一定具有 PRF 安全性。

常见的非均匀来源包括：

- 某些密钥交换协议产生的共享秘密；
- 带偏置或质量不稳定的硬件随机源；
- 组合多个熵源得到的原始材料。

2.5 Extract-then-Expand

标准范式分为两步：

第一步：Extract

从可能非均匀、但包含足够熵的 SK 中提取近似均匀的伪随机密钥：

$$PRK = \text{Extract}(\text{salt}, SK).$$

第二步：Expand

把 PRK 作为 PRF 密钥，并结合上下文和计数器扩展：

$$OKM = \text{Expand}(PRK, CTX, L).$$

这里：

- PRK 是 Pseudorandom Key；
- OKM 是 Output Keying Material；
- salt 通常是公开值，不是密码；
- salt 可以帮助提取和分离不同实例。

2.6 HKDF

HKDF 使用 HMAC 实现 Extract-then-Expand。高层形式为：

$$PRK = \text{HMAC}(\text{salt}, IKM),$$

然后使用 PRK 作为 HMAC 密钥，结合 info 和计数器产生输出块：

$$T_i = \text{HMAC}(PRK, T_{i-1} \parallel \text{info} \parallel i).$$

最终：

$$OKM = T_1 \parallel T_2 \parallel \dots$$

并截断到所需长度。

在 HKDF 的标准术语中：

- IKM 对应输入密钥材料；
- salt 是公开盐；
- info 对应讲义中的上下文信息；
- L 是所需输出长度。

2.7 HKDF 不适合直接处理低熵口令

用户口令通常来自很小的字典，例如常用单词、日期和短数字。即使 HKDF 能把它变成外观随机的长输出，也不会增加口令本身的熵。

攻击者可以离线枚举候选口令：

1. 对每个候选 `pwd'` 运行同样的 KDF；
2. 检查派生结果是否能正确解密或通过认证；
3. 找到匹配项后恢复真实口令。

因此，从口令派生密钥需要专门的 Password-Based KDF。

2.8 口令 KDF

讲义强调两项防御：

- **salt**：为每个用户或口令随机生成公开盐，阻止预计算彩虹表并避免相同口令得到相同派生值；
- **慢计算**：让每次口令猜测都付出更高时间成本。

讲义给出历史上的 PKCS#5/PBKDF1 形式：

$$H^{(c)}(pwd \parallel salt),$$

表示迭代哈希 `c` 次。

今天的新系统通常优先考虑 Argon2id、scrypt，或在兼容场景中使用 PBKDF2，并根据部署环境选择成本参数。HKDF 与这些算法的任务不同：

工具	输入假设	主要目标
HKDF	输入材料有足够熵但可能不均匀	提取并扩展密钥材料
PBKDF	人类口令熵较低	提高每次字典猜测成本

3. 确定性加密

3.1 为什么需要确定性加密

普通语义安全加密使用随机数或 nonce，同一明文多次加密通常得到不同密文。

但数据库索引可能需要：

1. 把用户名 Alice 确定性地加密为某个索引；
2. 以后查询 Alice 时再次计算同一密文；
3. 直接在加密数据库中找到对应记录。

如果每次加密结果都不同，就无法进行这种等值查找。

3.2 确定性加密不可能满足普通 CPA 安全

确定性加密满足：

$$E(k, m) = E(k, m)$$

每次结果都相同。攻击者可以：

1. 查询 m_0 的加密，得到 c_0 ；
2. 在挑战中提交 m_0 与 m_1 ；
3. 收到挑战密文 c ；
4. 比较 c 是否等于 c_0 。

若相等则挑战消息是 m_0 ，否则是 m_1 。攻击者以概率 1 获胜。

因此：

确定性加密必然泄露相等关系，不能满足普通随机化加密的 CPA 定义。

当消息空间很小或分布可预测时，攻击者还可以建立“明文 - 密文”字典，泄露可能非常严重。

3.3 确定性 CPA 安全的限制

课程定义了较弱的 deterministic CPA security，简称 dCPA。挑战阶段仍选择：

$$m_{i,0}, m_{i,1}, \quad |m_{i,0}| = |m_{i,1}|,$$

但要求两边各自的消息序列都不重复：

$$m_{1,0}, \dots, m_{q,0} \text{ 互不相同,}$$

$$m_{1,1}, \dots, m_{q,1} \text{ 互不相同.}$$

这个定义只考虑同一密钥下消息不重复的场景，例如：

- 加密从大空间均匀随机生成的密钥；
- 每条记录带有唯一用户 ID；
- 消息结构本身保证唯一。

它没有消除确定性加密的泄露，而是把不可避免的重复泄露排除在安全游戏之外。

3.4 固定 IV 的 CBC 为什么不安全

固定 IV 的 CBC 第一块为：

$$c[1] = E_k(m[1] \oplus FIV).$$

攻击者可以构造两条互不相同的多分组消息，使其中某个分组输入与另一条消息的第一块输入相同，然后通过比较对应密文块区分挑战世界。

更直观地说，固定 IV 的 CBC 会泄露两个消息的公共前缀长度：只要前 i 个明文分组相同，前 i 个密文分组也相同。这比确定性加密不可避免的“整条消息是否相等”泄露更多。

因此，固定 IV 的 CBC 甚至不满足讲义中的 dCPA 安全。

3.5 固定 IV 的 CTR 为什么不安全

CTR 在固定 IV 下重复使用同一密钥流：

$$c = m \oplus F(k, FIV).$$

对两条消息：

$$c = m \oplus pad,$$

$$c' = m' \oplus pad.$$

攻击者计算：

$$c \oplus c' = m \oplus m'.$$

这会泄露两条明文的异或关系，远超确定性加密允许的相等模式泄露，所以也不满足 dCPA 安全。

4. SIV：合成初始化向量

4.1 基本构造

设：

- $F(k_1, m)$ 是安全 PRF，输出可作为随机化加密所需的随机数或 IV；
- $E(k_2, m; r)$ 是使用随机数 r 的 CPA 安全加密。

定义合成 IV：

$$r = F(k_1, m),$$

再计算：

$$c = E(k_2, m; r).$$

于是确定性加密为：

$$E_{det}((k_1, k_2), m) = E(k_2, m; F(k_1, m)).$$

因为同一条消息总产生同一个 r ，所以整体是确定性的；不同消息在 PRF 假设下产生看似独立的 r 。

4.2 为什么满足 dCPA

dCPA 游戏中，每一侧的挑战消息互不相同。因此输入 $F(k_1, m_i)$ 也互不相同。

若 F 是安全 PRF，这些输出与独立随机值不可区分。于是每条不重复消息都像使用了新随机数进行 CPA 安全加密。

SIV 特别适合长度超过一个 AES 分组的消息，因为它可以在现有随机化长消息加密方案外增加一层合成 IV。

4.3 SIV-CTR

以 CTR 模式为例：

1. 计算：

$$IV = F(k_1, m).$$

2. 使用独立密钥 k_2 ，以 IV 为 CTR 初始值生成密钥流：

$$pad = F_{ctr}(k_2, IV) \parallel F_{ctr}(k_2, IV + 1) \parallel \dots$$

3. 加密：

$$c = m \oplus pad.$$

4. 输出：

$$IV \parallel c.$$

4.4 解密与完整性验证

收到 $IV \parallel c$ 后：

1. 用 k_2 和 IV 做 CTR 解密，得到候选消息 m' ；
2. 重新计算：

$$IV' = F(k_1, m').$$

3. 检查：

$$IV' \stackrel{?}{=} IV.$$

若不相等则输出 $\perp$ ；相等才接受 m' 。

因此，SIV-CTR 不仅提供 dCPA 安全，还能提供密文完整性，形成 Deterministic Authenticated Encryption，简称 DAE。

可以把合成 IV 理解为“由整条消息计算出的认证值，同时又被用作加密随机化材料”。攻击者修改 IV 或密文后，通常无法让重新计算的 IV 仍然匹配。

4.5 SIV 与普通 nonce 模式的区别

普通随机化加密	SIV 确定性加密
IV/nonce 来自外部或随机源	IV 由消息和密钥合成
同一消息多次加密通常不同	同一消息和密钥下结果相同
正确使用时隐藏重复消息	必然泄露消息是否重复
nonce 重用可能灾难性破坏安全	设计目标包括更强的误用抵抗，但仍有重复泄露

5. 从 PRP 构造确定性加密

5.1 单分组消息

安全 PRP:

$$E : K \times X \rightarrow X$$

本身就是固定长度消息上的确定性加密候选。对于互不相同的输入，随机置换的输出是互不相同且看似随机的值。

因此，安全 PRP 在 dCPA 的不重复消息条件下提供确定性语义安全。AES 可用于 16 字节消息空间，但不能直接处理更长消息。

5.2 宽分组 PRP

若要把整条长消息作为一个置换单元，需要构造 Wide-Block PRP。讲义给出的 EME 可以把 n 位分组密码扩展为 N 位消息空间上的 PRP，其中：

$$N \gg n.$$

EME 通过多次分组密码调用和混合，使任一输入分组变化都影响整个输出。相较于 SIV，它可能大约慢两倍，但能够在整个长消息空间上形成真正的置换。

5.3 用冗余获得确定性认证加密

假设有一个定义在扩展空间上的安全 PRP:

$$E : K \times (X \times \{0, 1\}^n) \rightarrow X \times \{0, 1\}^n.$$

加密时在消息后附加 n 位固定冗余:

$$c = E_k(x \parallel 0^n).$$

解密时计算:

$$x' \parallel r = D_k(c).$$

仅当:

$$r = 0^n$$

时接受 x' ，否则输出 $\perp$ 。

5.4 完整性为什么约为 2^{-n}

把理想 PRP 看作随机置换。攻击者提交一个新的密文 c ，其逆像近似为扩展空间中的随机未使用点。

逆像最后 n 位恰好等于 0^n 的概率至多约为:

$$\frac{1}{2^n}.$$

如果 n 足够大，该概率可忽略，于是固定冗余同时充当了有效性检查。

这里的关键不是“零比特很神秘”，而是合法明文只占扩展输入空间的 2^{-n} ；攻击者很难让随机伪造的逆像落入这个合法子集。

6. 磁盘加密为什么特殊

6.1 密文不能扩张

磁盘被划分为固定大小扇区，例如 4 KB。加密前后必须恰好占用同样空间：

$$|M| = |C|.$$

通常没有空间为每个扇区额外存储随机 nonce 和认证标签。因此，课程讨论的经典磁盘加密场景具有：

- 无密文扩张；
- 确定性操作；
- 通常不提供完整性。

6.2 为什么必须是 PRP

若确定性加密的消息空间与密文空间大小相等，并且可以正确解密，那么固定密钥下加密必须是一一映射。

否则两个明文映射为同一密文，解密算法无法唯一恢复原文。因此：

$$M = C \quad \text{且可逆} \implies E(k, \cdot) \text{ 是置换.}$$

所以，每个扇区需要通过某种 PRP 加密。

6.3 所有扇区使用同一个 PRP 的问题

若每个扇区都直接使用同一置换：

$$c_t = E_k(m_t),$$

则内容相同的两个扇区会产生相同密文：

$$m_i = m_j \implies c_i = c_j.$$

这会产生类似 ECB 的跨扇区模式泄露。

6.4 每个扇区独立密钥

一种改进是为扇区 t 派生独立密钥：

$$k_t = PRF(k, t),$$

再计算：

$$c_t = E_{k_t}(m_t).$$

相同内容位于不同扇区时会产生不同密文。但逐扇区派生和管理的直接方案成本较高，而且攻击者仍能观察同一扇区何时变化、何时回滚到旧内容。

这引出了 tweakable encryption。

7. 可调分组密码

7.1 定义

可调分组密码的接口为：

$$E, D : K \times T \times X \rightarrow X.$$

其中 $t \in T$ 称为 tweak。对每个固定的密钥 k 和 tweak t ：

$$E(k, t, \cdot) : X \rightarrow X$$

都必须是可逆置换。

安全目标是：不同 tweak 下的置换看起来像相互独立的随机置换族。

7.2 tweak 是什么

tweak 是公开的非秘密参数，用来选择“当前使用哪一个置换”。在磁盘加密中可以令：

$$t = (\text{sector number}, \text{block index}).$$

这样，即使相同 16 字节明文出现在不同扇区或不同块位置，也会经过不同的逻辑置换。

7.3 tweak、nonce 和密钥的区别

参数	是否秘密	是否必须唯一	主要作用
密钥 k	是	会话或用途内固定	提供不可预测性和访问控制
nonce	否	通常要求同一密钥下唯一	随机化一次加密调用
tweak	否	可重复，但重复会复用同一置换	选择公开上下文对应的置换

tweak 不是第二把密钥。安全性不依赖攻击者不知道 tweak，攻击者甚至可以主动选择 tweak 进行查询。

7.4 安全实验

真实世界为：

$$\pi[t](x) = E(k, t, x).$$

理想世界则为每个 tweak t 独立采样一个随机置换：

$$\pi[t] \leftarrow \text{Perm}[X].$$

攻击者可以查询：

$$(t_1, x_1), (t_2, x_2), \dots, (t_q, x_q),$$

并尝试区分真实构造与独立随机置换族。

7.5 直接构造

若普通 PRP 的密钥空间与输入空间兼容，可以先派生 tweak 对应的密钥：

$$k_t = E(k, t),$$

再计算：

$$E_{tweak}(k, t, x) = E(k_t, x).$$

这种构造概念清楚，但每加密一个块需要两次分组密码运算。

8. XTS 磁盘加密

8.1 基本思想

XTS 使用两把密钥 k_1 、 k_2 ：

- k_2 根据扇区号产生初始掩码；
- k_1 执行实际的数据分组加密。

对扇区号 t ：

$$N = E(k_2, t).$$

再根据块位置 i 从 N 计算位置相关掩码 Δ_i ，概念上写为：

$$\Delta_i = P(N, i).$$

第 i 个明文块 x 的加密形式为：

$$c = E(k_1, x \oplus \Delta_i) \oplus \Delta_i.$$

这种结构称为 XEX：先异或掩码、执行分组密码、再异或同一掩码。

8.2 效率

一个扇区有 n 个块时：

- 计算 $N=E(k_2, t)$ 需要一次 AES；
- 每个数据块使用 k_1 做一次 AES；
- 掩码通过有限域中的高效运算从前一个位置推进。

总计约为 $n+1$ 次 AES 调用，比为每个块重新派生密钥更高效。

8.3 为什么要先加密 tweak

如果直接把公开的 t 或简单位置编码作为掩码，攻击者可能利用不同 tweak 之间的代数关系构造可区分等式。

先计算：

$$N = E(k_2, t)$$

可以把公开且结构化的扇区号转换为攻击者无法预测其关系的伪随机起点，再为每个块派生不同掩码。

8.4 XTS 的安全边界

XTS 是窄分组可调模式：每次底层置换仍处理一个 AES 分组，而不是把整个扇区作为一个宽分组。

因此：

- 相同明文块位于不同扇区或块位置时，通常得到不同密文；

- 改变一个密文块通常只影响对应明文块；
- 它不提供密码学完整性；
- 攻击者仍可修改、复制或回滚磁盘密文；
- 同一位置恢复旧密文会恢复旧明文，XTS 本身无法检测回滚。

XTS 的目标是长度保持的磁盘保密性，不是认证加密。对于需要防篡改的存储系统，必须另行设计认证、元数据和防回滚机制。

8.5 XTS 与 EME

模式	置换单位	特点
XTS	单个 AES 块，带扇区与位置 tweak	高效，适合磁盘，但扩散仅限局部
EME	整个宽消息或扇区	全局扩散更强，通常约慢两倍

9. 保格式加密 FPE

9.1 为什么需要保持格式

信用卡号、电话号码、身份证号和数据库旧字段往往有固定格式。某些中间系统只接受符合格式的数据，例如：

- 只能包含十进制数字；
- 长度固定；
- 某些前缀具有业务含义；
- 末尾包含校验位；
- 必须通过旧系统的数据类型检查。

普通 AES 输出是任意二进制串，不能直接填入这些字段。

FPE 的目标是：

明文属于某个格式域，密文仍然属于同一个格式域。

9.2 把格式映射到整数域

假设所有有效格式值共有 s 个。先建立双射：

$$Encode : Format \rightarrow \{0, \dots, s-1\},$$

$$Decode : \{0, \dots, s-1\} \rightarrow Format.$$

加密流程：

1. 把有效信用卡号映射为 $x \in \{0, \dots, s-1\}$ ；
2. 在这个整数域上应用 PRP，得到 y ；
3. 把 y 映射回一个有效信用卡号格式。

所以真正的核心问题是：

如何在 $\{0, \dots, s-1\}$ 上构造安全 PRP？

9.3 第一步：构造 2^t 大小域上的 PRP

选择 t ，使：

$$2^{t-1} < s \leq 2^t.$$

使用安全 PRF 的截断版本，并通过 Luby-Rackoff/Feistel 网络构造 t 位空间上的 PRP：

$$E : K \times \{0, 1\}^t \rightarrow \{0, 1\}^t.$$

讲义图示使用多轮 Feistel，并指出实际安全分析可采用更多轮数，例如 Patarin 分析下的七轮方案。核心思想是利用 PRF 构造可逆且伪随机的置换。

9.4 第二步：Cycle Walking

现在有 2^t 个可能值，但目标域只有前 s 个值。定义：

$$E' : K \times \{0, \dots, s-1\} \rightarrow \{0, \dots, s-1\}.$$

对输入 x ：

```
y = x
重复：
    y = E(k, y)
直到 y < s
输出 y
```

这称为 Cycle Walking：沿着大域置换的循环不断前进，直到重新进入目标子集。

解密时使用逆置换 D 同样循环，直到回到目标子集。

9.5 为什么平均迭代次数不超过约 2

因为：

$$2^{t-1} < s \leq 2^t,$$

目标域至少占大域的一半：

$$\frac{s}{2^t} > \frac{1}{2}.$$

随机一步落入目标域的概率大于 $1/2$ ，所以期望迭代次数小于 2。

9.6 为什么仍然是置换

大域中的 E 是置换，其元素被分成若干不相交循环。Cycle Walking 相当于在每个循环中跳过不属于目标域的节点，只保留目标域节点之间的顺序。

因此，它仍然在目标子集上形成一一映射。若大域上是随机置换，限制后得到的目标域置换也具有相应安全性。

9.7 FPE 的安全边界

FPE 保留格式，也就保留了格式本身带来的小消息空间问题。

例如信用卡号的有效空间远小于 128 位 AES 空间，攻击者可能利用：

- 频率分析；
- 已知格式与前缀；
- 小域枚举；
- 重复值泄露；
- 业务数据库中的辅助信息。

讲义中的构造是确定性 PRP，因此同一密钥下相同输入产生相同输出。它也不自动提供完整性，攻击者修改后的密文仍可能是另一个格式合法的值。

因此：

“看起来仍像信用卡号”只表示格式保持，不表示消息已经经过认证，也不表示所有业务信息都被隐藏。

10. 四个主题的关系

主题	要解决的约束	核心工具	必然或典型泄露
KDF	一个源密钥派生多个用途密钥	PRF、Extract-then-Expand、HKDF	不用于隐藏 CTX、salt 或输出长度
确定性加密	需要重复查询同一密文索引	SIV、PRP、宽分组 PRP	相同明文产生相同密文
磁盘加密	密文不能扩张，位置应参与加密	tweakable PRP、XTS	修改、回滚与局部模式仍可能可见
FPE	密文必须属于原格式域	Feistel PRP、Cycle Walking	格式、小域、频率和重复关系

共同原则是：

现实接口限制会迫使方案泄露某些信息。密码学设计必须精确定义“允许泄露什么”，而不能继续声称满足普通随机化加密的全部安全目标。

11. 易混概念对照

11.1 salt、nonce、CTX 与 tweak

参数	是否秘密	主要用途	重复的影响
salt	否	帮助提取、阻止口令预计算、分离实例	口令场景中重复会恢复跨用户预计算优势
nonce	否	让同一密钥下不同调用使用不同随机化状态	许多模式中重复会严重破坏安全
CTX/info	否	标记协议、方向和用途，实现域分离	相同输入可能派生相同用途密钥

参数	是否秘密	主要用途	重复的影响
tweak	否	选择公开上下文对应的置换	重复表示复用同一个置换，不必然违规

11.2 HKDF 与 PBKDF

HKDF 假定输入已有足够熵，只是可能不均匀；PBKDF 面对的是低熵的人类口令，需要提高字典攻击成本。HKDF 不能把弱口令“变强”。

11.3 SIV 与随机 IV

随机 IV 来自外部随机源；Synthetic IV 由消息和密钥计算。SIV 通过接受重复泄露，换取确定性或 nonce 误用时更稳健的行为。

11.4 XTS 与认证加密

XTS 只解决固定长度磁盘块的保密性与位置分离，不验证密文是否被修改。AES-XTS 不是 AEAD。

11.5 FPE 与哈希或编码

FPE 是带密钥且可逆的置换；哈希通常不可逆；Base64 等编码没有秘密密钥，也不提供保密性。

12. 常见误区

误区 1: KDF 可以增加源密钥的熵

错误。KDF 可以提取并扩展已有熵，却不能凭空创造熵。低熵口令仍然可被字典枚举。

误区 2: salt 必须保密

错误。salt 通常公开。它的作用是分离实例、帮助提取或阻止预计算，而不是充当第二个密码。

误区 3: 所有子密钥都用 $H(SK)$ 即可

错误。不同用途需要 CTX、标签和计数器实现域分离，否则不同协议可能重复使用同一密钥材料。

误区 4: 确定性加密也能完全隐藏重复消息

错误。同一密钥下相同明文必然产生相同密文，这是确定性加密无法避免的泄露。

误区 5: 只要消息不完全相同，固定 IV 的 CBC 就安全

错误。它还会泄露公共前缀和分组相等关系，因而不满足课程定义的 dCPA 安全。

误区 6: 固定 IV 的 CTR 是确定性 PRG 加密，所以安全

错误。重复密钥流会泄露两条明文的异或关系。

误区 7: SIV 中的 IV 是随机生成的

错误。它是消息在秘密 PRF 下的输出，因此称为 Synthetic IV。

误区 8: XTS 能检测磁盘篡改

错误。XTS 不提供认证，不能检测比特修改、复制或回滚。

误区 9: tweak 是需要保密的第二把密钥

错误。tweak 是公开上下文，例如扇区号和块位置。

误区 10: FPE 输出格式正确，所以一定是合法原始数据

错误。FPE 只保证格式域内的可逆映射，不自动保证完整性或业务真实性。

13. 必记公式

均匀源密钥的 PRF 扩展：

$$KDF(SK, CTX, L) = F(SK, CTX \parallel 0) \parallel F(SK, CTX \parallel 1) \parallel \dots$$

HKDF 提取：

$$PRK = HMAC(salt, IKM).$$

SIV：

$$\begin{aligned} r &= F(k_1, m), \\ c &= E(k_2, m; r). \end{aligned}$$

确定性认证的 PRP 冗余构造：

$$c = E_k(x \parallel 0^n).$$

伪造通过概率：

$$\Pr[\text{accept forgery}] \lesssim 2^{-n}.$$

可调分组密码：

$$E : K \times T \times X \rightarrow X.$$

XTS/XEX 高层形式：

$$c = E(k_1, x \oplus \Delta_i) \oplus \Delta_i.$$

FPE 域大小选择：

$$2^{t-1} < s \leq 2^t.$$

Cycle Walking：

$$y \leftarrow E(k, y) \quad \text{直到} \quad y < s.$$

14. 自测题

题目

1. 为什么一个会话通常需要多把不同用途的密钥？
2. KDF 中 CTX 的主要作用是什么？
3. 非均匀 SK 为什么要先进行 Extract？
4. HKDF 为什么不适合作为普通用户口令的直接防护方案？
5. salt 是否需要保密？在口令 KDF 中有什么作用？
6. 为什么确定性加密不可能满足普通 CPA 安全？
7. dCPA 游戏为什么要求每一侧的消息序列互不重复？
8. 固定 IV 的 CBC 会泄露什么额外信息？
9. 固定 IV 的 CTR 为什么会泄露明文异或？
10. SIV 中的合成 IV 是怎样产生的？
11. SIV-CTR 解密时为什么要重新计算 IV？
12. 为什么安全 PRP 可以用于单分组的确定性加密？
13. 在 PRP 输入后附加 0^n ，为什么能够提供完整性检查？
14. 为什么不扩张且可逆的磁盘加密必须是置换？
15. tweak 与 nonce 有何区别？
16. XTS 如何使相同数据位于不同磁盘位置时产生不同密文？
17. XTS 是否能防止磁盘扇区回滚？
18. Cycle Walking 为什么仍然得到目标子集上的置换？
19. 为什么讲义构造中 Cycle Walking 的期望迭代次数约不超过 2？
20. FPE 为什么不能自动提供完整性？

参考答案

1. 不同方向、算法和用途需要逻辑隔离，避免跨协议相互影响，并限制单个密钥泄露的范围。
2. 标记协议、方向、会话和用途，实现域分离，让相同 SK 在不同上下文中产生独立子密钥。
3. PRF 安全通常要求均匀密钥。Extract 把含有足够熵但可能偏置的输入材料转换为近似均匀的 PRK。
4. HKDF 不会增加低熵口令的猜测难度，攻击者仍可高速进行离线字典攻击；口令需要专用慢 KDF。
5. 不需要。它阻止跨用户预计算和彩虹表，并使相同口令在不同 salt 下得到不同结果。
6. 攻击者可先获得某条消息的密文，再与挑战密文比较，从而立即判断挑战消息。
7. 重复消息必然产生重复密文。dCPA 通过限制消息不重复，只评价确定性方案在其适用场景中的额外泄露。
8. 它会泄露不同消息的公共前缀长度和分组相等关系。
9. 两次使用同一密钥流时， $c \oplus c' = (m \oplus \text{pad}) \oplus (m' \oplus \text{pad}) = m \oplus m'$ 。
10. 使用安全 PRF 从消息本身计算 $IV = F(k_1, m)$ 。
11. 重新计算值必须与密文携带的 IV 相同；否则说明 IV 或密文被修改，应返回 $\perp$ 。
12. 固定密钥后的安全 PRP 是可逆置换，对不重复输入给出互不相同且看似随机的输出。
13. 合法输入只占扩展输入空间约 2^{-n} 。新伪造密文的随机逆像末尾恰好为 0^n 的概率约为 2^{-n} 。
14. 可逆性要求每个明文唯一对应一个密文；当消息空间与密文空间等大时，这个一一映射必然是置换。
15. nonce 通常用于区分每次加密并要求唯一；tweak 用于公开选择一个置换，允许重复，但重复会复用相同置换。
16. 它把扇区号和块位置转换为位置相关掩码，在 AES 加密前后执行异或。
17. 不能。攻击者把某位置恢复为旧密文时，会恢复旧明文，XTS 没有认证状态来发现回滚。
18. 大域置换由不相交循环组成；跳过循环中不在目标域的节点后，目标域节点仍保持一一对应。

19. 因为目标域大小 s 大于 2^{t-1} ，至少占 2^t 大域的一半，每次进入目标域的概率大于 $1/2$ 。
20. 它只是格式域上的可逆置换，攻击者修改密文后仍可能得到另一个格式合法值，没有标签来验证来源。

15. 一页复习提纲

1. KDF 从一个源密钥派生多把用途隔离的子密钥。
2. 均匀 SK 可通过 PRF 加 CTX 和计数器扩展；CTX 用于域分离。
3. 非均匀高熵材料采用 Extract-then-Expand；HKDF 用 HMAC 实现这一范式。
4. HKDF 不适合低熵口令；口令需要 salt 和昂贵的专用 KDF。
5. 确定性加密必然泄露相等关系，因此不能满足普通 CPA 安全。
6. dCPA 只讨论每一侧消息不重复的场景。
7. 固定 IV 的 CBC 泄露公共前缀，固定 IV 的 CTR 泄露明文异或，二者都不是安全确定性加密。
8. SIV 用 PRF 从消息计算合成 IV，再执行随机化加密。
9. SIV-CTR 解密后重新计算 IV；匹配才接受，因此可形成 DAE。
10. 安全 PRP 可以加密一个固定长度分组；EME 等宽分组模式可扩展到长消息。
11. PRP 输入附加 n 位固定冗余，伪造通过概率约为 2^{-n} 。
12. 磁盘扇区不允许密文扩张，所以需要长度保持的置换。
13. 可调分组密码通过公开 tweak 从一把密钥得到许多逻辑独立的置换。
14. XTS 使用扇区号和块位置产生掩码，效率约为每扇区 $n+1$ 次 AES。
15. XTS 不提供完整性，不能检测修改、复制或回滚。
16. FPE 在原格式域上构造 PRP，使密文仍满足信用卡号等格式。
17. Cycle Walking 在 2^t 大域上迭代 PRP，直到输出回到 $\{0, \dots, s-1\}$ 。
18. FPE 仍泄露小域、格式、频率和重复关系，也不自动提供认证。

16. 本课关系图

一个源密钥 SK

- ├ 输入近似均匀：PRF + CTX + counter
- └ 输入非均匀但有熵：Extract → Expand (HKDF)
 - └ 低熵口令不能直接用：改用慢速 PBKDF

特殊加密接口

- ├ 需要密文可查询：确定性加密
 - ├ 必然泄露重复
 - └ SIV / wide PRP / DAE
- ├ 磁盘不能扩张：tweakable PRP
 - ├ tweak = 扇区号 + 块位置
 - └ XTS：保密但不认证
- └ 输出必须符合原格式：FPE
 - ├ Feistel 构造 2^t 域上的 PRP
 - └ Cycle Walking 限制到目标小域

本课最重要的思想是：**特殊功能通常意味着允许特定泄露。只有先明确应用约束与安全定义，才能判断一个构造是否真正适用。**